

Third-Party Risk Guideline

Nexus Communications · Security

Document Name: Third-Party Risk Guideline

Company: Nexus Communications

Company ID: nexuscomms

Department: Security

Industry: telco

Version: 1.2

Audience: External auditors and regulators

Privacy Level: Internal

Date of Creation: 2026-10-04

Date of Update: 2026-10-04

Format: PDF

Estimated Pages: 5

Controls and Requirements

Security maintains this standard on behalf of Nexus Communications to keep telco operations defensible. Each operational task must be recorded in the control log before it is presented to a customer. Automated checks run continuously and alert the on-call engineer when thresholds are breached. New starters shadow an experienced owner until they can process a operational task unaided. Changes to telco practice are evaluated by the Security change advisory board.

Evidence of compliance is retained for a minimum of seven years in the central records system. Where this document conflicts with legislation, the stricter requirement always prevails. Reconciliation of first-time-right rate is performed before the review period reporting cycle is closed. The standing target for first-time-right rate is agreed with the Risk Lead and reported each review period. Third parties are bound by these terms through contractual clauses in their statement of work. Escalation proceeds to the Risk Lead when the material threshold is not restored in time.

Business continuity plans assume the Third-Party Risk capability can be restored within review period. Evidence of testing is captured automatically and attached to the control record. Metrics covering availability and error rate are published to stakeholders each review period. Failures exceeding the material impact threshold trigger a formal incident record. Teams outside Security consume the process record read-only; changes are requested through the Risk Lead. Templates for approval workflow are versioned centrally so that Security does not maintain local copies.

Roles and Responsibilities

Personnel joining Security complete this training before receiving production credentials. The Risk Lead is accountable for confirming that this document is followed in practice. Access is granted on a least-privilege basis and recertified every review period. Training is mandatory before production access is granted to the Third-Party Risk environment. Ownership rests with the Security head, who may delegate day-to-day operation to a named owner. Historical records remain queryable for audit purposes for the full retention window.

Material changes to telco regulation are assessed for impact within review period. Where supplier engagement is urgent, the shortened route is used and logged for review afterwards. Capacity to absorb first-time-right rate is reassessed every review period and signed off by the Risk Lead. Performance against the commitments in this document is reported to the Risk Lead each review period. Commercial terms relating to supplier engagement may not be varied without written sign-off.

Disputes about operational task are settled by reference to the control log and the recorded decision. Systems that process Third-Party Risk data must enforce encryption at rest and in transit. Departments that consume backlog age are notified before the figures are restated. Corrections to backlog age are explained in the commentary that accompanies the control log. Any correction to the control log is versioned, with the superseded version retained for audit. Approval for any change to the control log is granted by the Risk Lead and logged with a reference.

Escalation and Incident Handling

A supplier engagement raised outside Security is handed to the Risk Lead rather than handled locally. Exceptions require written approval from the Risk Lead and are logged with a review date. The Risk Lead may suspend the process record entries without notice where risk warrants it. Clauses covering supplier engagement are reviewed by Security before any renewal is negotiated. Customer-facing commitments made about supplier engagement are traceable to a clause in the process record.

Every control described here is reviewed at least once per review period by an independent reviewer. The Risk Lead reviews cost per unit alongside financial results to confirm the change request assumptions hold. Applies to all staff, contractors and automated systems that support the Third-Party Risk lifecycle. Where change request cannot be completed as described, the fallback path is recorded in the process record.

Teams outside Security consume the process record read-only; changes are requested through the Risk Lead. The standing target for first-time-right rate is agreed with the Risk Lead and reported each review period. Any correction to the process record is versioned, with the superseded version retained for audit. Business continuity plans assume the Third-Party Risk capability can be restored within review period. Any deviation must be raised within one business day through the Third-Party Risk intake channel. Each supplier engagement must be recorded in the process record before it is presented to a customer. Corrections to first-time-right rate are explained in the commentary that accompanies the process record.

Standard Operating Procedure

A customer commitment raised outside Security is handed to the Risk Lead rather than handled locally. The Risk Lead is accountable for confirming that this document is followed in practice. Applies to all staff, contractors and automated systems that support the Third-Party Risk lifecycle. Evidence of testing is captured automatically and attached to the control record. Where customer commitment cannot be completed as described, the fallback path is recorded in the process record.

Exceptions require written approval from the Risk Lead and are logged with a review date. Disputes about supplier engagement are settled by reference to the operational register and the recorded decision. Where this document conflicts with legislation, the stricter requirement always prevails. Metrics covering availability and error rate are published to stakeholders each review period.

Systems that process Third-Party Risk data must enforce encryption at rest and in transit. Changes to telco practice are evaluated by the Security change advisory board. Failures exceeding the material impact threshold trigger a formal incident record. Departments that consume throughput are notified before the figures are restated. New starters shadow an experienced owner until they can process a supplier engagement unaided.

Compliance Monitoring

Access is granted on a least-privilege basis and recertified every review period. Training is mandatory before production access is granted to the Third-Party Risk environment. Historical records remain queryable for audit purposes for the full retention window. Personnel joining Security complete this training before receiving production credentials. Clauses covering operational task are reviewed by Security before any renewal is negotiated.

Performance against the commitments in this document is reported to the Risk Lead each review period. Templates for change request are versioned centrally so that Security does not maintain local copies. The Risk Lead may suspend the operational register entries without notice where risk warrants it. Every control described here is reviewed at least once per review period by an independent reviewer. Capacity to absorb backlog age is reassessed every review period and signed off by the Risk Lead.

Commercial terms relating to operational task may not be varied without written sign-off. Automated checks run continuously and alert the on-call engineer when thresholds are breached. Ownership rests with the Security head, who may delegate day-to-day operation to a named owner. The Risk Lead reviews cost per unit alongside financial results to confirm the operational task assumptions hold. Evidence of compliance is retained for a minimum of seven years in the central records system.

Access recertification	Service Owner	Each review period
Change approval	Process Manager	Per change
Backup restore test	Control Owner	Each review period
Log retention review	Compliance Officer	Each review period

Purpose and Objectives

Escalation proceeds to the Risk Lead when the material threshold is not restored in time. Data used to calculate throughput is sourced from the monitoring stack and is not adjusted without approval. Material changes to telco regulation are assessed for impact within review period. Where approval workflow is urgent, the shortened route is used and logged for review afterwards. Third parties are bound by these terms through contractual clauses in their statement of work. Customer-facing commitments made about approval workflow are traceable to a clause in the process record. Approval for any change to the process record is granted by the Risk Lead and logged with a reference.

Systems that process Third-Party Risk data must enforce encryption at rest and in transit. Evidence of testing is captured automatically and attached to the control record. Teams outside Security consume the control log read-only; changes are requested through the Risk Lead. Where approval workflow cannot be completed as described, the fallback path is recorded in the control log.

Control	Owner	Frequency
Access recertification	Service Owner	Each review period
Change approval	Process Manager	Per change
Backup restore test	Control Owner	Each review period
Log retention review	Compliance Officer	Each review period

Policy Statement

Access is granted on a least-privilege basis and recertified every review period. Metrics covering availability and error rate are published to stakeholders each review period. Controls are mapped to the wider assurance framework to avoid duplicated effort. Data used to calculate cost per unit is sourced from the monitoring stack and is not adjusted without approval. Business continuity plans assume the Third-Party Risk capability can be restored within review period. The Risk Lead is accountable for confirming that this document is followed in practice. Training is mandatory before production access is granted to the Third-Party Risk environment.

Personnel joining Security complete this training before receiving production credentials. Any deviation must be raised within one business day through the

Third-Party Risk intake channel. Where approval workflow is urgent, the shortened route is used and logged for review afterwards. Departments that consume throughput are notified before the figures are restated.

Role	Responsibility	Escalation
Control Owner	Operates and evidences the co	Process Manager
Process Manager	Approves changes and exceptio	Risk Lead
Risk Lead	Maintains the risk register	Compliance Officer
Compliance Officer	Reports to stakeholders	Executive sponsor